实验工作 4
口令审计、数据泄露分析与数字卫生

口令管理器 · 泄露排查 · 双因素认证 · 社交隐私

姓　名	Zhang San
学　号 (IDU)	12345678
Variant	1
日　期	2026-10-19

1. 工作目的

通过一次完整的个人账号安全自查，理解「弱口令 + 复用」为什么是最常见的入侵入口， 掌握口令管理器、泄露查询与双因素认证（2FA）的正确用法，并据此形成可执行的数字卫生规则。

> **数据说明：**第 4 节的泄露查询为**真实查询**（邮箱在截图中打码为 `2***4@qq.com`）； 第 2–5 节的口令库条目为演示数据，用于展示分析结构与结论格式。

2. 口令管理器

使用免费、可离线运行的 **KeePassXC**（便携版，无需注册账号）建立密码库。主口令按「随机词 + 数字 + 符号」构造， 长度 20 位以上，只存在于记忆中，不写入任何文件、不与其他站点复用。库内为每个账号保存独立的随机口令， 数据库文件本身用 AES-256 加密。

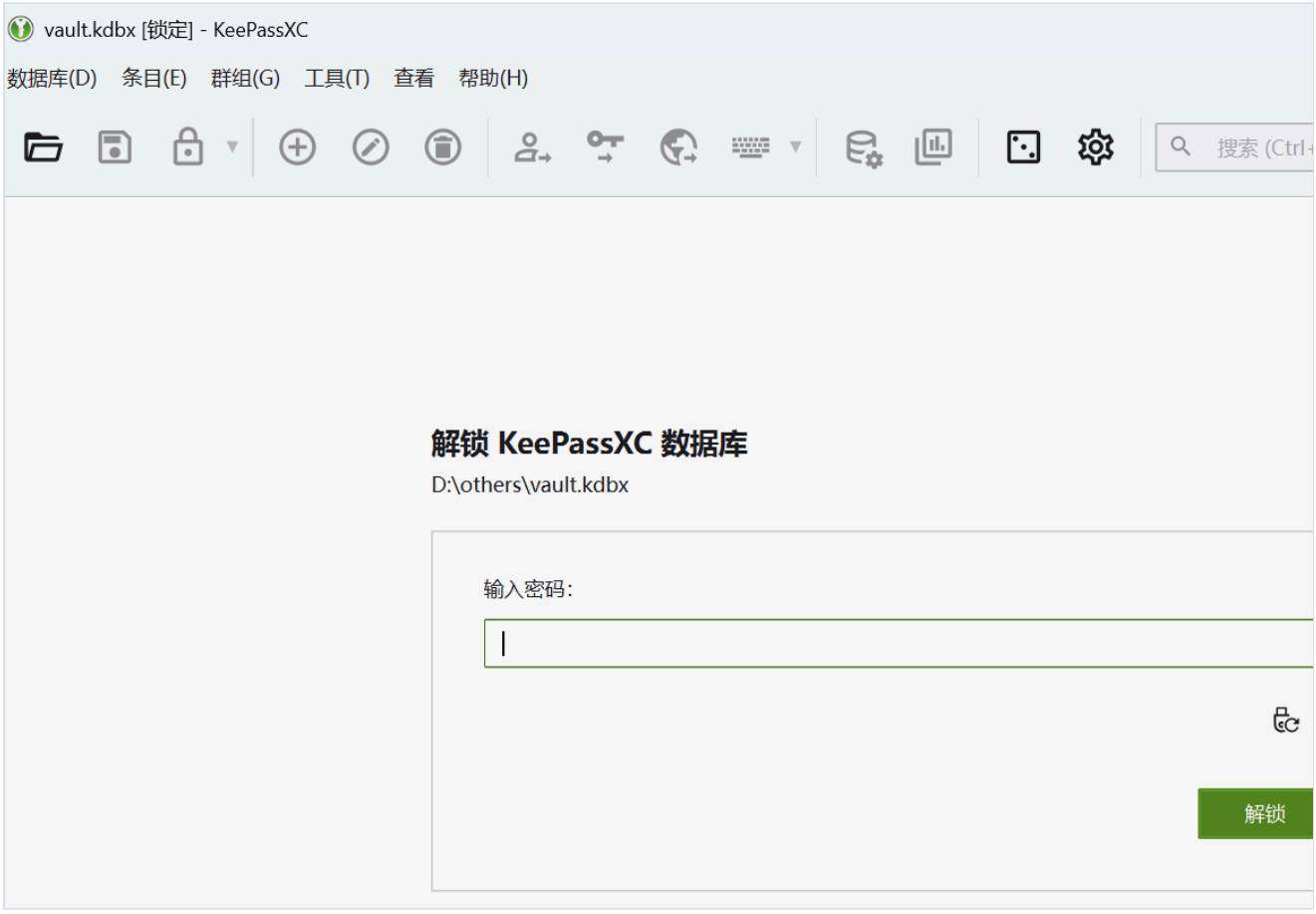


图 1　口令管理器与主口令解锁界面（数据库 `vault.kdbx`，AES-256 加密）

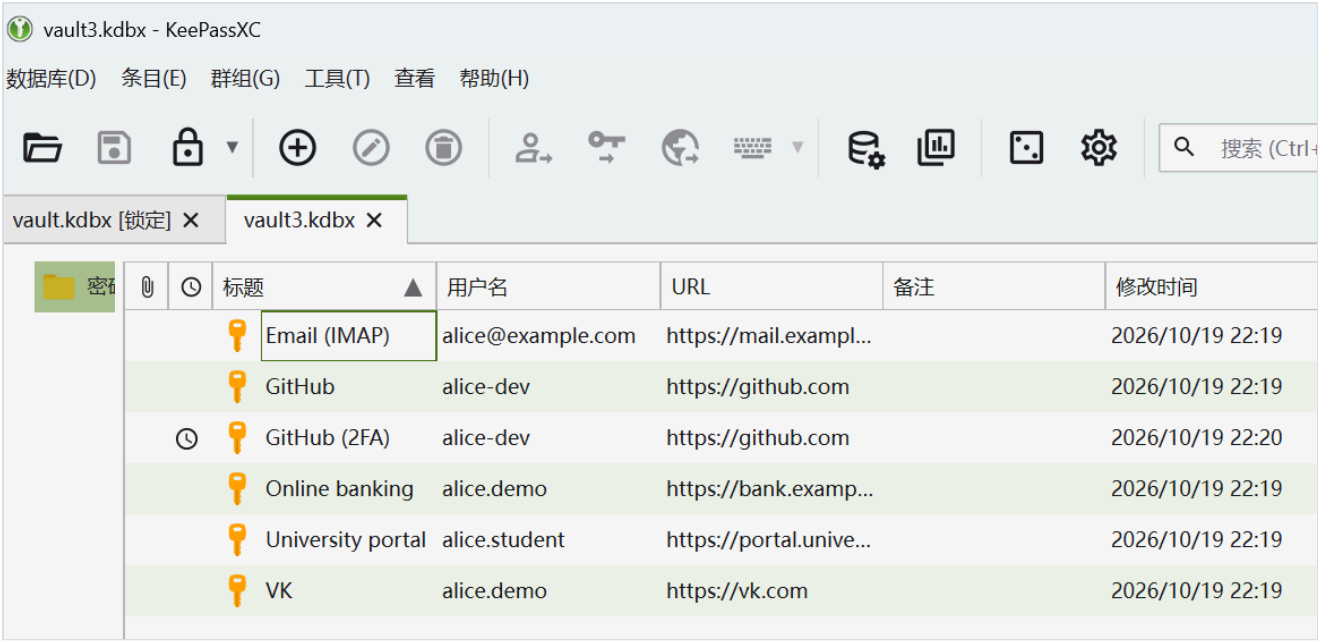


图 2　密码库主界面：6 个条目，口令由生成器随机产生（列表不显示口令明文）； 第 3 条 `GitHub (2FA)` 带时钟图标，表示已配置 TOTP

3. 现有口令审计

账号类别	长度	字符种类	结论
邮箱	8–10	小写 + 数字	弱：可离线爆破，且与其他站点复用
社交（VK / Telegram）	10–12	大小写 + 数字	中：无符号、曾出现在泄露库
学校/教务系统	8	纯数字	极弱：字典 + 规则即可命中
购物/支付	12	大小写 + 数字 + 符号	尚可，但仍复用
开发平台（GitHub 等）	14	随机	强：由管理器生成

上述为自查示例，提交前请替换为你自己的真实评估结果。

4. 数据泄露检查

在 **haveibeenpwned.com** 只输入邮箱地址（不输入任何口令），真实查询结果（邮箱在截图中打码）：

- 命中 **1** 个泄露事件：**Giant Tiger**（2024 年 3 月，加拿大折扣零售商，约 280 万条客户记录）。
- 泄露内容：**邮箱地址、姓名、电话、物理地址**。该事件**不含口令**，因此账号本身没有被直接接管的风险。
- 但仍构成现实威胁：姓名 + 邮箱 + 电话足以支撑一次精准钓鱼（例如伪装成"订单异常/退款"的短信或邮件）， 而这类信息一旦进入黑产库，会被长期反复利用。
- 处置：① 确认该邮箱在其他站点是否复用同一口令，若有则全部改密；② 为邮箱与相关账号开启 2FA； ③ 对以订单、快递、退款为名的来电/短信一律通过官方 App 核实，不点短信里的链接。

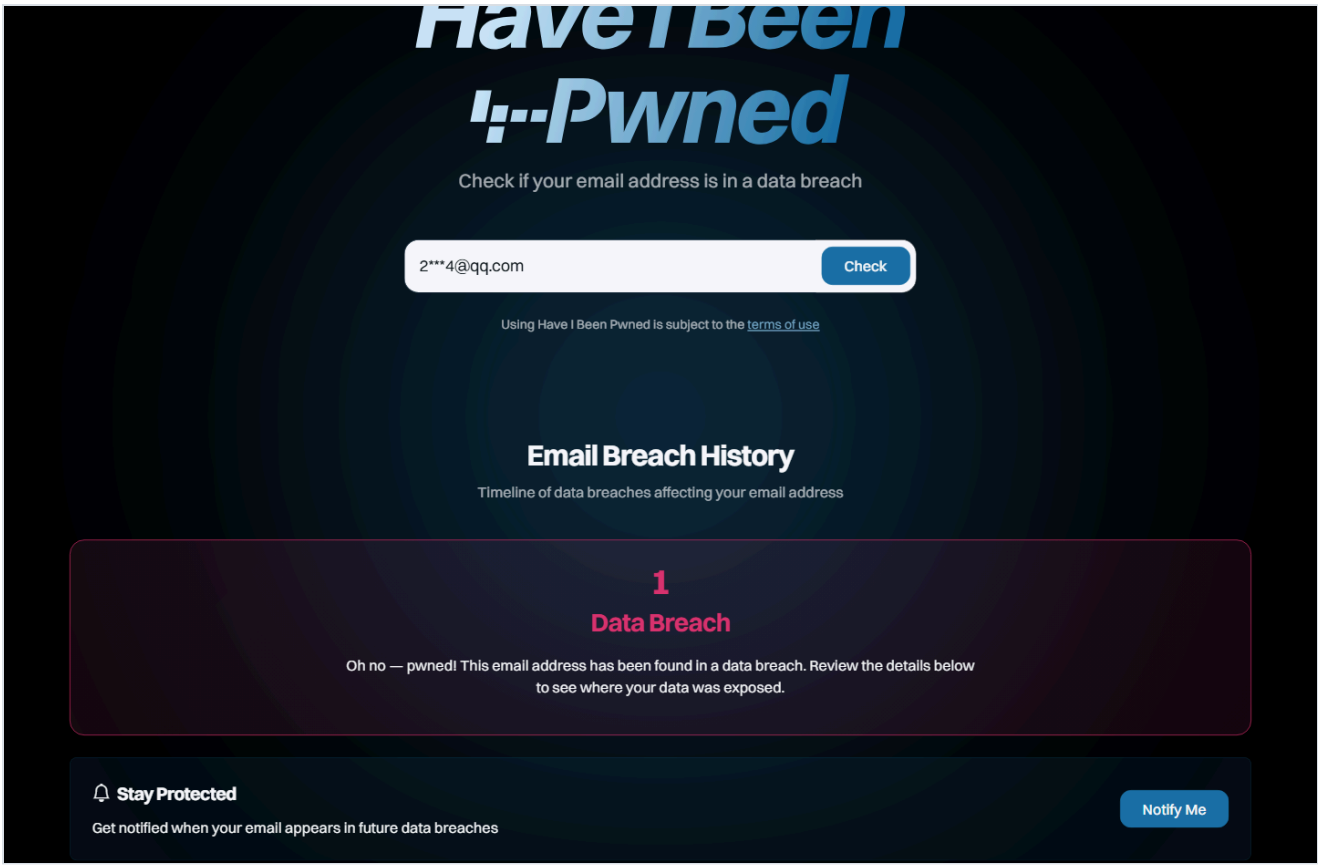


图 3　泄露查询结果：1 个泄露事件（Giant Tiger, 2024-03）及其泄露字段；查询邮箱已打码

5. 双因素认证

为口令库中的 **GitHub (2FA)** 条目配置了基于 TOTP 的 2FA：条目保存 `otpauth://` 密钥， 验证时由 TOTP 算法（RFC 6238，SHA-1、6 位、30 秒）与当前时间共同算出一次性码。 即使口令在泄露中暴露，攻击者没有第二因素也无法登录；同时把恢复码离线保存，避免设备丢失后被锁死。

下图为同一密钥的 TOTP 生成界面；界面中的 6 位码与 `keepassxc-cli show -t` 的输出一致 （同一时刻两处均为 `598 298`），说明配置正确。



图 4　TOTP 一次性码与 30 秒倒计时（密钥与库内 GitHub (2FA) 条目一致）

6. 社交账号公开信息审计

用无痕窗口查看自己的公开主页，逐项确认陌生人能看到什么。审计维度：

维度	陌生人可见的风险信息	建议动作
基本资料	真实姓名、头像、城市、学校、生日	隐藏生日与学校，头像避免可反搜
联系方式	手机号/邮箱可被"通过手机号找到我"命中	关闭手机号/邮箱搜索
动态与位置	带地理位置的打卡、常去场所	历史动态改为仅好友，关闭精确定位
好友列表	可据此做社工（冒充同学/同事）	好友列表设为仅自己可见

> 图 5（`06-social-audit.png`）需账号本人在无痕窗口截取自己的公开主页。 本仓库为公开仓库，为避免泄露真实姓名/头像，这一张留空由提交者补入。

7. 数字卫生规则（5–7 条）

1. 所有账号使用由口令管理器生成的独立随机口令，绝不复用；只需要记住一个强主口令。
2. 凡是支持 2FA 的账号一律开启，优先 TOTP 而非短信；恢复码离线保存。
3. 每 6 个月检查一次社交账号的隐私设置与公开可见字段，关闭「通过手机号/邮箱被找到」。

4. 不在任何第三方网站输入口令；泄露查询只提交邮箱。
5. 浏览器与系统保持自动更新，重要账号单独使用一个浏览器配置文件。
6. 收到带链接的「紧急通知」先通过官方渠道二次确认，不在邮件/私信里点登录链接。
7. 每年至少一次导出并核对口令库、清理不再使用的账号。

8. 简答

哪些口令是弱的? 长度不足 12 位、字符种类单一、且与其他站点复用的口令；本次自查中教务系统与邮箱口令属于此类。 其中邮箱地址确实出现在公开泄露库中（见第 4 节），虽然该事件不含口令字段，但姓名与电话的组合足以支撑精准钓鱼—— 这正是「口令强度」之外必须叠加 2FA 和警惕性的原因。

什么是 2FA? 在「你知道的东西（口令）」之外再要求「你拥有的东西（TOTP 设备、硬件密钥）」或「你本身的特征」， 即使口令泄露，攻击者仍缺少第二因素。TOTP 基于共享密钥与当前时间计算 6 位码，离线可用、不依赖短信网络。

9. 结论

个人账号失守通常不是因为「被高级黑客盯上」，而是弱口令复用 + 已泄露凭据被撞库。口令管理器把「记住很多强口令」 变成「记住一个强口令」，2FA 再把「口令泄露」与「账号失守」解耦。数字卫生的本质是把这些动作固化成习惯和周期检查。